ADR_009 以 JWT 維持登入狀態

> 狀態：已接受
> 日期：2026-10-14

背景

三種帳號都以帳號密碼登入（需求 3.13）。登入後，每個請求都要能識別帳號類型、帳號、所屬賣家與角色。

需要考慮的情況：

- 主應用程式之後可能部署多台，甚至拆成多個服務，每台都要能驗證請求的身分
- 搶購時請求量很大，驗證身分不應成為額外的瓶頸
- 帳號被鎖定、角色被移除時，權限要能收回

考慮過的選項

選項	優點	缺點
伺服器端工作階段	登出與權限收回立即生效；實作單純	多台機器需要共用工作階段儲存（例如 Redis），每個請求都要查一次；拆服務時每個服務都要能存取它
JWT 權杖	權杖本身帶有身分與角色，任何一台機器都能自行驗證，不必查詢共用儲存；適合多台部署與日後拆服務	權杖發出後在到期前都有效，無法立即收回；權杖內容會被看見，不能放敏感資料

決定

採用 JWT，並以「短效存取權杖」搭配「長效更新權杖」彌補無法立即收回的缺點：

項目	做法
存取權杖	有效 15 分鐘；內含帳號類型、帳號編號、所屬賣家編號（賣家帳號）、角色；不含個人資料
更新權杖	有效 7 天；存於資料庫，可以撤銷；每次使用後換發新的，舊的立即失效
簽章	使用非對稱金鑰簽章。日後拆出的服務只需要公鑰就能驗證，不必持有簽發用的私鑰
權限收回	帳號鎖定、停用、角色變更、登出、變更密碼時，撤銷該帳號所有的更新權杖。已發出的存取權杖最晚 15 分鐘後失效
驗證	每個請求以 Spring Security 驗證存取權杖的簽章與期限，再依角色與資料歸屬做授權

後果

- 好處：驗證身分不需要查資料庫或共用儲存，對高併發與多台部署友善；拆服務時各服務可以各自驗證
- 代價：權限收回有最長 15 分鐘的延遲，需求 3.13 已明確接受；需要維護更新權杖的儲存、換發與撤銷，以及簽章金鑰
- 重新檢討的條件：若出現必須立即收回權限的需求，改為存取權杖搭配撤銷清單，或縮短存取權杖的效期